

**ANKARA ÜNİVERSİTESİ
MÜHENDİSLİK FAKÜLTESİ
BİLGİSAYAR MÜHENDİSLİĞİ BÖLÜMÜ**



BLM 4522 PROJE RAPORU

Ağ Tabanlı Paralel Dağıtım Sistemleri

Vize 2. Proje

Veri Tabanı Güvenliği ve Erişim Kontrolü

<https://github.com/zeyneph61/Ag-Tabanli-Paralel-Dagitim-Sistemleri-Projeleri>

<https://youtu.be/gFiFvMUyTB4?si=TM4ZdPLiS9VgKYuV>

Zeynep Hacısalihoğlu

22290449

İÇİNDEKİLER

İÇİNDEKİLER	3
1. Giriş.....	4
1.1 Kullanılan Ortam.....	4
1.2 Projenin Amacı	5
1.3 Proje Planı	5
1.4 Mevcut Durum	6
1.5 Authentication Modu.....	7
2. Erişim Yönetimi	8
2.1 Login Oluşturma	8
2.2 Kullanıcı ve Rol Atama	8
2.3 Yetki Testi - db_readonly.....	10
2.4 Yetki Testi — db_dataentry	12
2.5 Yetki Testi - db_admin.....	14
3. Veri Şifreleme (TDE - Transparent Data Encryption)	16
4. SQL Injection Testleri.....	19
4.1 Savunmasız Senaryo (Unsafe).....	19
4.2 Güvenli Senaryo (Safe)	20
4.3 Kalıcı Güvenlik Önlemleri	21
5. Audit Logları.....	23
6. Güvenlik Duvarı Yönetimi.....	26
6.1 Neden Güvenlik Duvarı?	26
6.2 Güvenlik Duvarı Kuralının Oluşturulması.....	26
6.3 Yapılandırmanın Doğrulanması	35
7. Sonuç.....	37

1. Giriş

Bu proje Microsoft SQL Server 2022 üzerinde çalışan Northwind veritabanı üzerinde kapsamlı bir güvenlik altyapısının tasarlanması ve uygulanmasını konu almaktadır.

Proje kapsamında dört temel güvenlik konusu ele alınmıştır: kullanıcı erişim yönetimi, veri şifreleme (TDE), SQL Injection saldırılarına karşı koruma ve audit logları ile kullanıcı aktivitelerinin izlenmesi.

1.1 Kullanılan Ortam

Veritabanı Sistemi: Microsoft SQL Server 2022 Developer Edition, Sürüm 16.0.1000.6

Yönetim Aracı: SQL Server Management Studio (SSMS)

Örnek Veritabanı: Northwind

1.2 Projenin Amacı

Bu projenin amacı, Microsoft SQL Server üzerinde gerçek bir veritabanı güvenlik altyapısı tasarlamak ve uygulamalı olarak test etmektir. Proje kapsamında ele alınan güvenlik konuları — erişim yönetimi, veri şifreleme, SQL Injection koruması, audit logları ve güvenlik duvarı yönetimi — modern veritabanı sistemlerinde karşılaşılan başlıca güvenlik tehditlerini yansıtmaktadır. Her konu teorik anlatımla sınırlı kalmayıp SQL sorguları ve sistem yapılandırmaları ile uygulanmış, sonuçlar ekran çıktıları ile doğrulanmıştır.

1.3 Proje Planı

Proje aşağıdaki sırayla planlanmış ve uygulanmıştır:

Erişim Yönetimi: Farklı yetki seviyelerinde kullanıcılar oluşturulmuş, rol tabanlı erişim kontrolü yapılandırılmış ve yetkiler test edilmiştir.

Veri Şifreleme (TDE): Veritabanı dosyaları Transparent Data Encryption ile disk üzerinde şifrelenmiştir.

SQL Injection Testleri: Savunmasız ve güvenli stored procedure'lar karşılaştırılmış, kalıcı koruma önlemleri uygulanmıştır.

Audit Logları: Kullanıcı aktiviteleri SQL Server Audit ile izlenmiş ve loglar sorgulanmıştır.

Güvenlik Duvarı Yönetimi: SQL Server'ın dinlediği TCP 1433 portu güvenlik duvarı kurallarıyla kısıtlanmıştır.

1.4 Mevcut Durum

Projeye başlamadan önce sistemdeki mevcut login'ler sorgulanmıştır:

```
```sql
SELECT name, type_desc, is_disabled
FROM sys.server_principals
WHERE type IN ('S', 'U')
ORDER BY name;
```
```

Sorgu çıktısında 2 SQL Login ve 7 Windows Login'in tanımlı olduğu görülmüştür.

| | name | type_desc | is_disabled |
|----|-----------------------------------|---------------|-------------|
| 1 | ##MS_PolicyEventProcessingLogin## | SQL_LOGIN | 1 |
| 2 | ##MS_PolicyTsqlExecutionLogin## | SQL_LOGIN | 1 |
| 3 | DESKTOP-DLHAT6J\Asus | WINDOWS_LOGIN | 0 |
| 4 | NT AUTHORITY\SYSTEM | WINDOWS_LOGIN | 0 |
| 5 | NT SERVICE\SQLAgent\$DB | WINDOWS_LOGIN | 0 |
| 6 | NT SERVICE\SQLTELEMETRY\$DB | WINDOWS_LOGIN | 0 |
| 7 | NT SERVICE\SQLWriter | WINDOWS_LOGIN | 0 |
| 8 | NT SERVICE\Winmgmt | WINDOWS_LOGIN | 0 |
| 9 | NT Service\MSSQL\$DB | WINDOWS_LOGIN | 0 |
| 10 | sa | SQL_LOGIN | 0 |

1.5 Authentication Modu

SQL Server'ın hangi kimlik doğrulama modunda çalıştığı aşağıdaki sorgu ile kontrol edilmiştir:

```
``sql
EXEC xp_loginconfig 'login mode';
``
```

Sonuç: Login mode Mixed olarak yapılandırılmıştır. Bu mod hem SQL Server Authentication hem de Windows Authentication kullanımına izin vermektedir.

| | name | config_value |
|---|------------|--------------|
| 1 | login mode | Mixed |

2. Erişim Yönetimi

2.1 Login Oluşturma

Üç farklı yetki seviyesini temsil eden kullanıcı oluşturulmuştur: db_admin tam yetkili yönetici, db_readonly yalnızca okuma yapabilen kullanıcı, db_dataentry ise veri okuma ve ekleme yetkisine sahip kullanıcıdır.

```
USE master;
CREATE LOGIN db_admin WITH PASSWORD = 'Admin123!';
CREATE LOGIN db_readonly WITH PASSWORD = 'Readonly123!';
CREATE LOGIN db_dataentry WITH PASSWORD = 'Dataentry123!';
```

2.2 Kullanıcı ve Rol Atama

Login'ler Northwind veritabanına kullanıcı olarak eklenmiş ve uygun roller atanmıştır:

```
USE Northwind;
CREATE USER db_admin FOR LOGIN db_admin;
CREATE USER db_readonly FOR LOGIN db_readonly;
CREATE USER db_dataentry FOR LOGIN db_dataentry;

ALTER ROLE db_owner ADD MEMBER db_admin;
ALTER ROLE db_datareader ADD MEMBER db_readonly;
ALTER ROLE db_datareader ADD MEMBER db_dataentry;
ALTER ROLE db_datawriter ADD MEMBER db_dataentry;
```

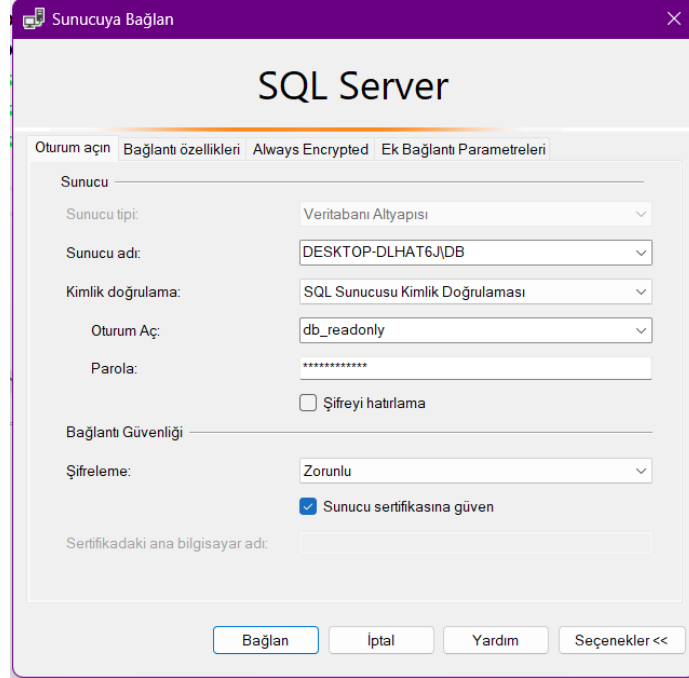

Sorgu çıktısı, her kullanıcının yalnızca kendisine atanan rolle eşleştiğini doğrulamaktadır. db_admin → db_owner, db_dataentry → db_datareader ve db_datawriter, db_readonly → db_datareader.

```
USE Northwind;
SELECT
    dp.name AS kullanıcı,
    rol.name AS rol
FROM sys.database_role_members rm
JOIN sys.database_principals dp ON rm.member_principal_id = dp.principal_id
JOIN sys.database_principals rol ON rm.role_principal_id = rol.principal_id
WHERE dp.name IN ('db_admin', 'db_readonly', 'db_dataentry')
ORDER BY dp.name;
```

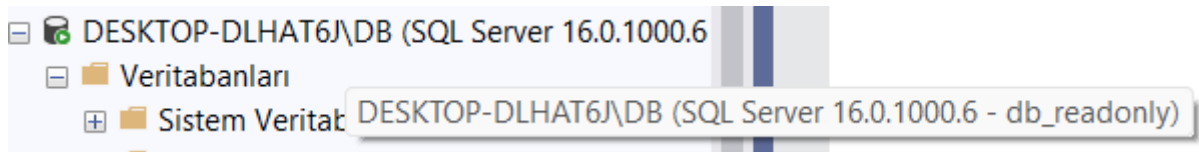
| Sonuçlar | | İletiler |
|----------|--------------|---------------|
| | kullanıcı | rol |
| 1 | db_admin | db_owner |
| 2 | db_dataentry | db_datareader |
| 3 | db_dataentry | db_datawriter |
| 4 | db_readonly | db_datareader |

2.3 Yetki Testi - db_readonly

Yetki testleri için SSMS'de yeni bir bağlantı açılmış ve SQL Server Authentication seçilmiştir.



db_readonly kullanıcısı ile DESKTOP-DLHAT6J\DB sunucusuna başarıyla bağlanılmıştır. Sol panelde bağlantının "db_readonly" kimliğiyle açıldığı görülmektedir.



Okuma testi (SELECT): Customers tablosundan veri sorgulanmış ve 5 kayıt başarıyla listelenmiştir. Bu, db_readonly kullanıcısının okuma yetkisine sahip olduğunu doğrulamaktadır.

```
``` sql
USE Northwind;
SELECT TOP 5 * FROM Customers;
```
```

| | CustomerID | CompanyName | ContactName | ContactTitle | Address | City | Region | PostalCode | Country | Phone | Fax |
|---|------------|------------------------------------|--------------------|----------------------|-------------------------------|-------------|--------|------------|---------|----------------|----------------|
| 1 | ALFKI | Alfreds Futterkiste | Maria Anders | Sales Representative | Obere Str. 57 | Berlin | NULL | 12209 | Germany | 030-0074321 | 030-0076545 |
| 2 | ANATR | Ana Trujillo Emparedados y helados | Ana Trujillo | Owner | Avda. de la Constitución 2222 | México D.F. | NULL | 05021 | Mexico | (5) 555-4729 | (5) 555-3745 |
| 3 | ANTON | Antonio Moreno Taquería | Antonio Moreno | Owner | Mataderos 2312 | México D.F. | NULL | 05023 | Mexico | (5) 555-3932 | NULL |
| 4 | AROUT | Around the Horn | Thomas Hardy | Sales Representative | 120 Hanover Sq. | London | NULL | WA1 1DP | UK | (171) 555-7788 | (171) 555-6750 |
| 5 | BERGS | Berglunds snabbköp | Christina Berglund | Order Administrator | Berguvsvägen 8 | Luleå | NULL | S-958 22 | Sweden | 0921-12 34 65 | 0921-12 34 67 |

Yazma testi (INSERT): Customers tablosuna yeni kayıt ekleme denenmiş, ancak "The INSERT permission was denied on the object 'Customers'" hatası alınmıştır. Bu sonuç, db_readonly kullanıcısının yazma yetkisinin olmadığını doğrulamaktadır.

```
``` sql
USE Northwind;
INSERT INTO Customers VALUES ('TEST', 'Test Firma', 'Mr', 'Test Co', NULL,
NULL, NULL, NULL, NULL, NULL, NULL);
```
```

 iletiler

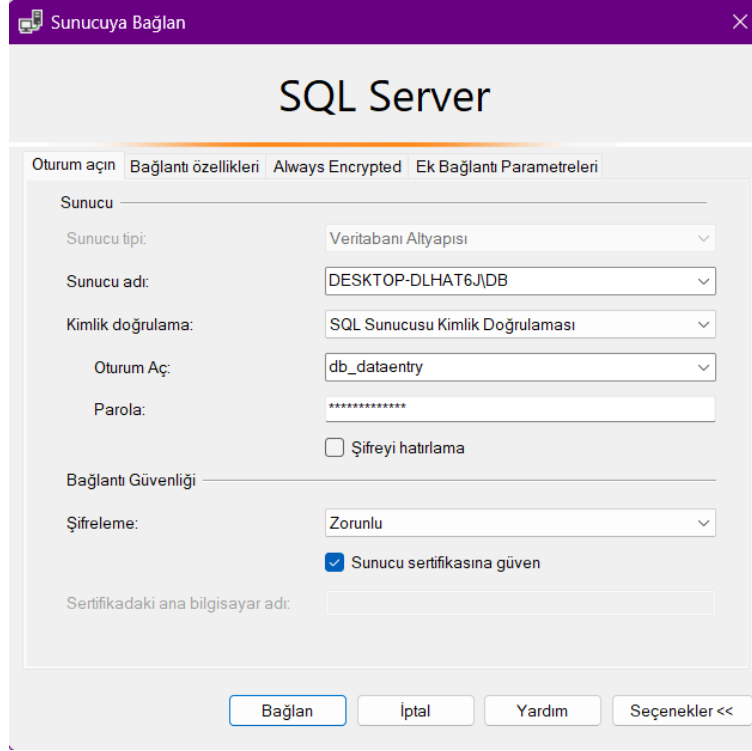
İleti 229, Düzey 14, Durum 5, Satır 2

The INSERT permission was denied on the object 'Customers', database 'Northwind', schema 'dbo'.

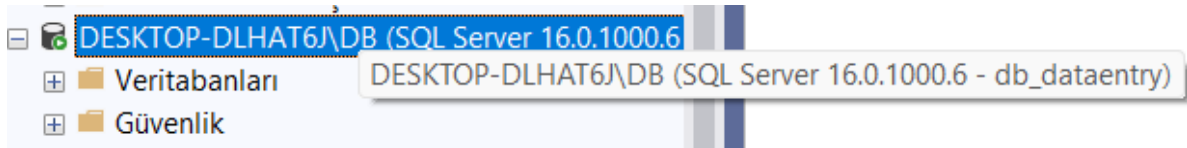
Tamamlanma süresi:2026-04-07T19:43:21.3368800+03:00

2.4 Yetki Testi — db_dataentry

db_dataentry kullanıcısı ile SQL Server Authentication kullanılarak bağlanılmıştır.

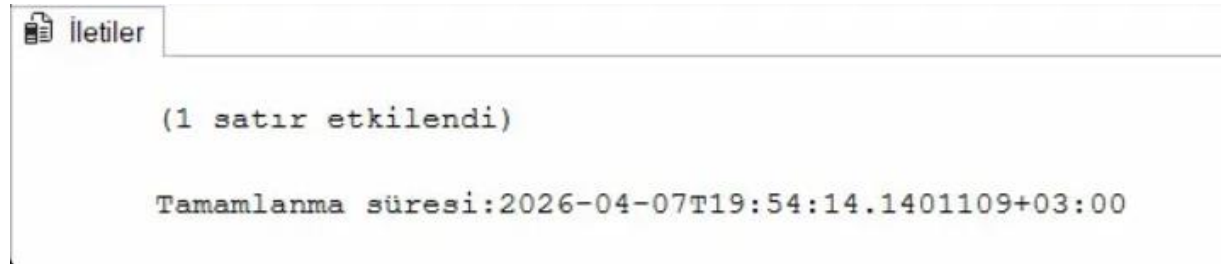


Bağlantının "db_dataentry" kimliğiyle açıldığı sol panelden doğrulanmıştır.



Yazma testi (INSERT): Customers tablosuna yeni bir kayıt eklenmiş ve işlem başarıyla tamamlanmıştır. "1 satır etkilendi" mesajı alınmıştır.

```
``` sql
USE Northwind;
INSERT INTO Customers VALUES ('TEST', 'Test Firma', 'Mr', 'Test Co', NULL,
NULL, NULL, NULL, NULL, NULL, NULL);
```
```



Doğrulama (SELECT): Eklenen TEST kaydı sorgulanmış ve tabloda başarıyla görüntülenmiştir.

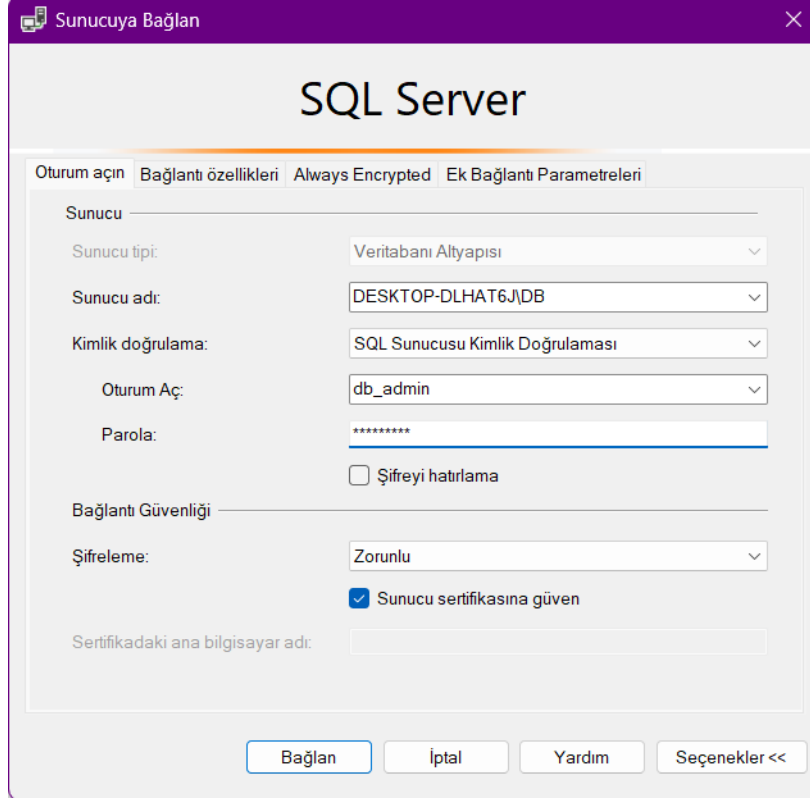
```
``` sql
USE Northwind;
SELECT * FROM Customers WHERE CustomerID = 'TEST';
```
```

| | CustomerID | CompanyName | ContactName | ContactTitle | Address | City | Region | PostalCode | Country | Phone | Fax |
|---|------------|-------------|-------------|--------------|---------|------|--------|------------|---------|-------|------|
| 1 | TEST | Test Firma | Mr | Test Co | NULL | NULL | NULL | NULL | NULL | NULL | NULL |

Bu sonuç db_dataentry kullanıcısının hem okuma hem de yazma yetkisine sahip olduğunu doğrulamaktadır. db_readonly kullanıcısının aynı işlemde hata aldığı düşünüldüğünde, rol tabanlı yetkilendirmenin doğru çalıştığı açıkça görülmektedir.

2.5 Yetki Testi - db_admin

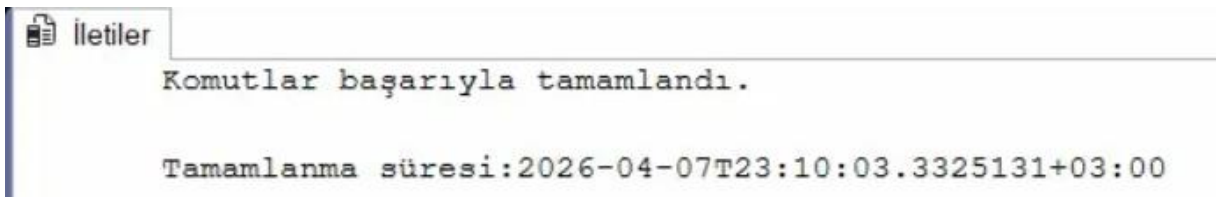
db_admin kullanıcısı ile bağlanılmıştır.



DDL testi (CREATE TABLE & DROP TABLE):

```
USE Northwind;  
CREATE TABLE AdminTest (ID INT, Aciklama NVARCHAR(50));  
DROP TABLE AdminTest;
```

İşlem başarıyla tamamlanmıştır.



db_admin kullanıcısı db_owner rolüne sahip olduğundan tablo oluşturma ve silme gibi DDL işlemlerini gerçekleştirebilmektedir. Bu işlem db_readonly ve db_dataentry kullanıcıları tarafından yapılamamaktadır.

| İşlem | db_readonly | db_dataentry | db_admin |
|--------------|-------------|--------------|----------|
| SELECT | İzinli | İzinli | İzinli |
| INSERT | Reddedildi | İzinli | İzinli |
| CREATE TABLE | Reddedildi | Reddedildi | İzinli |

3. Veri Şifreleme (TDE - Transparent Data Encryption)

TDE veritabanı dosyalarını disk üzerinde şifreleyerek fiziksel erişim durumunda veri güvenliğini sağlar. Şifreleme uygulama katmanında değil, doğrudan veritabanı motoru tarafından gerçekleştirilir.

TDE etkinleştirildiğinde veritabanı dosyaları (.mdf, .ldf) ve yedek dosyalar (.bak) otomatik olarak şifrelenir. Şifreleme ve çözme işlemi arka planda gerçekleştiği için uygulama tarafında herhangi bir değişiklik gerekmez.

Uygulama dört adımda gerçekleştirilmiştir:

Adım 1 - Master Key oluşturuldu:

Master Key, sunucu düzeyinde şifreleme hiyerarşisinin temelidir. Tüm sertifikalar ve anahtarlar bu key ile korunur.

```
USE master;  
CREATE MASTER KEY ENCRYPTION BY PASSWORD = 'MasterKey123!';
```

Adım 2 - Sertifika oluşturuldu:

Sertifika veritabanı şifreleme anahtarını korumak için kullanılır. Sertifika kaybolursa şifreli veritabanına bir daha erişilemez bu nedenle yedeklenmesi kritik önem taşır.

```
CREATE CERTIFICATE NorthwindTDECert  
WITH SUBJECT = 'Northwind TDE Sertifikası';
```


Adım 3 - Şifreleme anahtarı oluşturuldu ve şifreleme etkinleştirildi:

```
USE Northwind;
CREATE DATABASE ENCRYPTION KEY
WITH ALGORITHM = AES_256
ENCRYPTION BY SERVER CERTIFICATE NorthwindTDECert;

ALTER DATABASE Northwind
SET ENCRYPTION ON;
```



İşlem sırasında "The certificate used for encrypting the database encryption key has not been backed up" uyarısı alınmıştır. Gerçek bir üretim ortamında sertifika mutlaka yedeklenmelidir. Yedekleme şu komutla yapılır:

```
BACKUP CERTIFICATE NorthwindTDECert
TO FILE = 'C:\NorthwindBackups\NorthwindTDECert.cer'
WITH PRIVATE KEY (
    FILE = 'C:\NorthwindBackups\NorthwindTDECert.pvk',
    ENCRYPTION BY PASSWORD = 'CertBackup123!'
);
```

Adım 4 - Şifreleme doğrulandı:

```
SELECT name, is_encrypted  
FROM sys.databases  
WHERE name = 'Northwind';
```

Sorgu çıktısında is_encrypted = 1 değeri, Northwind veritabanının başarıyla şifrelendiğini doğrulamaktadır.

| Sonuçlar | |
|---|--------------|
| name | is_encrypted |
| Northwind | 1 |
| (1 satır etkilendi) | |
| Tamamlanma süresi:2026-04-07T23:23:01.1783402+03:00 | |

4. SQL Injection Testleri

SQL Injection, kullanıcı girdisinin SQL sorgusuna doğrudan eklenmesiyle oluşan ve saldırganların yetkisiz veri erişimi sağlamasına olanak tanıyan yaygın bir güvenlik açığıdır.

Bu bölümde önce saldırıya açık bir senaryo oluşturulmuş ve injection'ın nasıl çalıştığı gözlemlenmiştir. Ardından parametrelili sorgu kullanan güvenli bir yapı ile karşılaştırma yapılmış ve kalıcı önlemler uygulanmıştır.

4.1 Savunmasız Senaryo (Unsafe)

Dinamik SQL kullanan savunmasız bir stored procedure oluşturulmuştur. Bu procedure, kullanıcıdan gelen girdiyi doğrudan sorguya yapıştırmaktadır:

```
USE Northwind;
GO

CREATE PROCEDURE sp_GetCustomer_Unsafe
    @CustomerID NVARCHAR(50)
AS
BEGIN
    EXEC('SELECT * FROM Customers WHERE CustomerID = ''' + @CustomerID + ''')
END;
```

Aşağıdaki injection saldırısı bu procedure üzerinde test edilmiştir:

```
EXEC sp_GetCustomer_Unsafe @CustomerID = 'ALFKI' OR '1'='1';
Girdi sorguya yapıştırıldığında oluşan SQL şu şekildedir:
```
```sql
SELECT * FROM Customers WHERE CustomerID = 'ALFKI' OR '1'='1'
```

'1'='1' ifadesi her zaman TRUE döndürdüğünden WHERE koşulu tüm satırlar için geçerli olmuş ve 92 satır yani tüm Customers tablosu döndürülmüştür. Yalnızca ALFKI kaydının gelmesi gerekirken saldırgan tüm müşteri verisine erişmiştir.

Bu sonuç kritik bir güvenlik açığını ortaya koymaktadır: saldırgan yalnızca tek bir müşteriye erişmesi gerekirken tüm müşteri tablosunu elde etmiştir. Gerçek bir sistemde bu tablo; adres, telefon ve iletişim bilgileri gibi kişisel verileri içerebilir.

Sonuçlar				
SPLIR	Split Rail Beer & Ale	Art Braunschweiger	Sales Manager	P.O. Box 555
SUPRD	Suprêmes délices	Fascale Cartrain	Accounting Manager	Boulevard Tirou, 255
TEST	Test Firma	Mr	Test Co	NULL
THEBI	The Big Cheese	Liz Nixon	Marketing Manager	89 Jefferson Way Suite 2
THECR	The Cracker Box	Liu Wong	Marketing Assistant	55 Grizzly Peak Rd.
TOMSP	Toms Spezialitäten	Karin Josephs	Marketing Manager	Luisenstr. 48
TORTU	Tortuga Restaurante	Miguel Angel Paolino	Owner	Avda. Asteca 123
TRADH	Tradição Hipermercados	Anabela Domingues	Sales Representative	Av. Inês de Castro, 414
TRATH	Trail's Head Gourmet Provisioners	Helvetius Nagy	Sales Associate	722 DaVinci Blvd.
VAFFE	Vaffeljernet	Palle Ibsen	Sales Manager	Smagsloget 45
VICTE	Victualles en stock	Mary Saveley	Sales Agent	2, rue du Commerce
VINET	Vins et alcools Chevalier	Paul Henriot	Accounting Manager	59 rue de l'Abbaye
WANDK	Die Wandernde Kuh	Rita Müller	Sales Representative	Adenauerallee 900
WARTH	Wartian Herku	Pirkko Koskitalo	Accounting Manager	Torikatu 38
WELLI	Wellington Importadora	Paula Parente	Sales Manager	Rua do Mercado, 12
WHITC	White Clover Markets	Karl Jablonski	Owner	305 - 14th Ave. S. Suite 3B
WILMK	Wilman Kala	Matti Karttunen	Owner/Marketing Assistant	Keskuskatu 45
WOLZA	Wolski Zajazd	Zbyszek Piastrianiewicz	Owner	ul. Filtrowa 68
(92 satır etkilendi)				

4.2 Güvenli Senaryo (Safe)

SQL Injection'a karşı koruma sağlamak için parametrelili sorgu kullanan güvenli bir stored procedure oluşturulmuştur:

```
USE Northwind;
GO

CREATE PROCEDURE sp_GetCustomer_Safe
    @CustomerID NVARCHAR(50)
AS
BEGIN
    SELECT * FROM Customers
    WHERE CustomerID = @CustomerID;
END;
```

Aynı injection saldırısı güvenli procedure üzerinde tekrarlanmıştır:

```
```sql
EXEC sp_GetCustomer_Safe @CustomerID = 'ALFKI' OR '1'='1';
```
```

Sonuç: Normal kullanımda yalnızca ALFKI kaydı gelmiş (1 satır), injection denemesinde ise 0 satır döndürülmüştür. Parametrelili sorgular kullanıcı girdisini SQL kodu olarak değil veri olarak işlediğinden saldırı etkisiz kalmıştır.

| Sonuçlar | | | | |
|---|---------------------|--------------|----------------------|---------------|
| CustomerID | CompanyName | ContactName | ContactTitle | Address |
| ALFKI | Alfreds Futterkiste | Maria Anders | Sales Representative | Obere Str. 57 |
| (1 satır etkilendi) | | | | |
| CustomerID | CompanyName | ContactName | ContactTitle | Address |
| (0 satır etkilendi) | | | | |
| Tamamlanma süresi:2026-04-08T00:29:16.2305293+03:00 | | | | |

Parametrelili sorgularda kullanıcı girdisi SQL motoru tarafından her zaman veri olarak işlenir, kod olarak değil. Bu nedenle ' OR '1'='1 ifadesi bir CustomerID değeri olarak aranmış ve eşleşme bulunamamıştır.

4.3 Kalıcı Güvenlik Önlemleri

Test sonrasında aşağıdaki kalıcı önlemler uygulanmıştır:

```
```sql
USE Northwind;

-- Tehlikeli procedure kaldırıldı
DROP PROCEDURE sp_GetCustomer_Unsafe;

-- Kullanıcıların tabloya direkt erişimi kapatıldı
DENY SELECT ON Customers TO db_readonly;
DENY SELECT ON Customers TO db_dataentry;

-- Sadece güvenli procedure üzerinden erişime izin verildi
GRANT EXECUTE ON sp_GetCustomer_Safe TO db_readonly;
GRANT EXECUTE ON sp_GetCustomer_Safe TO db_dataentry;
```
```

Bu sayede kullanıcılar Customers tablosuna doğrudan erişemez, yalnızca güvenli procedure üzerinden veri sorgulayabilir.

Bu yapılandırma sonucunda kullanıcılar Customers tablosuna artık doğrudan erişememektedir. Tüm sorgular yalnızca sp_GetCustomer_Safe üzerinden yapılabilmekte bu da injection saldırılarına karşı kalıcı bir koruma katmanı oluşturmaktadır. Bir sonraki bölümde bu erişim girişimleri audit loglarıyla izlenecektir.

5. Audit Logları

Erişim yönetimi ve SQL Injection koruması tek başına yeterli değildir. Sistemde kimin ne zaman ne yaptığının da kayıt altına alınması gerekir. Audit logları; yetkisiz erişim girişimlerini, başarısız sorguları ve şüpheli aktiviteleri tespit etmek için kullanılır.

Kullanıcı aktivitelerini izlemek için SQL Server Audit kullanılmıştır.

Adım 1 - Server Audit oluşturuldu:

```
USE master;
GO
CREATE SERVER AUDIT NorthwindAudit
TO FILE (FILEPATH = 'C:\NorthwindBackups\')
WITH (ON_FAILURE = CONTINUE);
GO
ALTER SERVER AUDIT NorthwindAudit WITH (STATE = ON);
GO
```

ON_FAILURE = CONTINUE ayarı, log dosyasına yazılamadığı durumlarda veritabanının çalışmaya devam etmesini sağlar. Kritik sistemlerde bu değer SHUTDOWN olarak ayarlanabilir; bu durumda loglama başarısız olursa sunucu kendini kapatır.

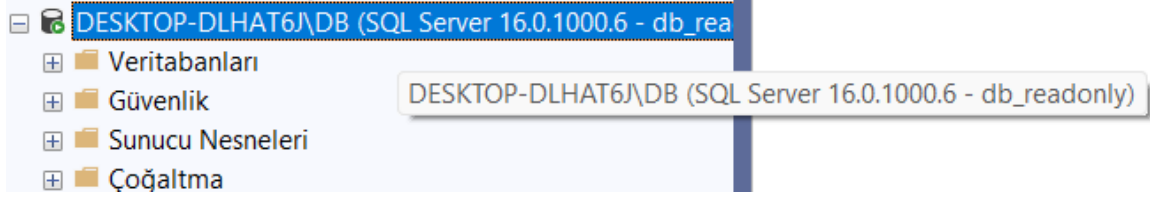
Adım 2 - Database Audit Specification oluşturuldu:

```
USE Northwind;
GO
CREATE DATABASE AUDIT SPECIFICATION NorthwindAuditSpec
FOR SERVER AUDIT NorthwindAudit
ADD (SELECT ON dbo.Customers BY db_readonly),
ADD (INSERT ON dbo.Customers BY db_dataentry),
ADD (DELETE ON dbo.Customers BY db_dataentry)
WITH (STATE = ON);
GO
```

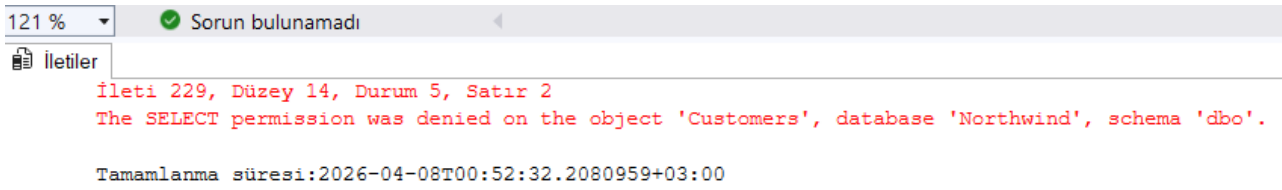
Audit specification yalnızca belirli kullanıcıların belirli tablolar üzerindeki işlemlerini izlemektedir. Bu sayede log dosyası gereksiz verilerle şişmez, yalnızca güvenlik açısından kritik olaylar kaydedilir.

Adım 3 - Test ve Doğrulama:

db_readonly kullanıcısıyla Customers tablosuna SELECT yapılmaya çalışılmış ancak daha önce uygulanan DENY kısıtlaması nedeniyle reddedilmiştir.



4. bölümde uygulanan DENY SELECT kısıtlaması nedeniyle db_readonly kullanıcısının doğrudan tablo erişimi engellenmiştir. Bu girişim reddedilmiş olsa da audit log tarafından kayıt altına alınmıştır.



Audit logları aşağıdaki sorgu ile sorgulanmıştır:

```
SELECT
    event_time,
    action_id,
    server_principal_name,
    object_name,
    succeeded
FROM sys.fn_get_audit_file('C:\NorthwindBackups\*.sqlaudit', DEFAULT, DEFAULT)
ORDER BY event_time DESC;
```

Log çıktısında db_readonly kullanıcısının SELECT girişimi (SL) ve audit specification'ın oluşturulması (AUSC) kayıt altına alınmıştır. Bu sonuç kullanıcı aktivitelerinin başarılı ve başarısız işlemler dahil olmak üzere eksiksiz loglandığını doğrulamaktadır.

| Sonuçlar | | |
|---|-----------|-----------------------|
| event_time | action_id | server_principal_name |
| 2026-04-07 21:52:32.1985595 | SL | db_readonly |
| 2026-04-07 21:50:24.3810455 | AUSC | DESKTOP-DLHAT6J\Asus |
| (2 satır etkilendi) | | |
| Tamamlanma süresi:2026-04-08T00:53:18.8681383+03:00 | | |

Log çıktısında iki kayıt görülmektedir: db_readonly kullanıcısının SELECT girişimi (SL) ve audit specification'ın oluşturulması (AUSC). SL kullanıcı aktivitesini, AUSC ise yapılandırma değişikliğini temsil etmektedir.

6. Güvenlik Duvarı Yönetimi

6.1 Neden Güvenlik Duvarı?

Veritabanı güvenliğinin sadece SQL Server içindeki önlemlerle sınırlı kalmaması gerekir. Dışarıdan gelen yetkisiz bağlantı girişimleri de engellenmelidir. SQL Server varsayılan olarak 1433 numaralı TCP portunu kullanır.

Bu port dışarıya açık bırakılırsa saldırganlar doğrudan SQL Server'a bağlanmaya çalışabilir, kaba kuvvet saldırısı yapabilir veya açıkları istismar edebilir.

Bu riski azaltmak için Windows Defender Güvenlik Duvarı üzerinde 1433 portuna yönelik kısıtlı erişim kuralı oluşturulmuştur.

6.2 Güvenlik Duvarı Kuralının Oluşturulması

Aşağıdaki yapılandırma adımları uygulanmıştır:

- Kural türü: Bağlantı noktası (Port)
- Protokol: TCP
- Port: 1433
- Eylem: Yalnızca belirtilen koşullarda izin ver
- Profil: Domain ve Private - Public devre dışı
- Uzak IP: Yalnızca 127.0.0.1 (localhost)

Windows Defender Güvenlik Duvarı üzerinde SQL Server için port tabanlı bir inbound kuralı oluşturulmuştur. Bu kural ile belirli bir port üzerinden gelen bağlantılar kontrol altına alınmıştır.

Yeni Gelen Kuralı Sihirbazı

Kural Türü
Oluşturulacak güvenlik duvarı kuralı türünü seçin.

Adımlar:

- Kural Türü
- Protokoll ve Bağl. Nokt.
- Eylem
- Profil
- Ad

Hangi türde bir kural oluşturmak istersiniz?

☐ **Program**
Bir programın bağlantılarını denetleyen kural.

☒ **Bağlantı noktası**
TCP veya UDP bağlantı noktasının bağlantılarını denetleyen kural.

☐ **Önceden tanımlı:**
@%systemroot%\system32\provsvc.dll,-202
Windows deneyimi bağlantılarını denetleyen kural.

☐ **Özel**
Özel kural.

< Geri Sonraki > İptal

Yeni Gelen Kuralı Sihirbazı

Protokoll ve Baęl. Nokt.

Bu kuralın uygulandığı protokolleri ve baęlantı noktalarını belirtin.

Adımlar:

Kural Tütü

Protokoll ve Baęl. Nokt.

Eylem

Profil

Ad

Bu kural TCP'ye mi yoksa UDP'ye mi uygulanacak?

☒ TCP

☐ UDP

Bu kural tüm yerel baęlantı noktalarına mı, yoksa belirli baęlantı noktalarına mı uygulanıyor?

☐ Tüm yerel baęlantı noktaları

☒ Belirli yerel baęlantı noktaları:

1433

Örnek: 80, 443, 5000-5010

< Geri

Sonraki >

İptal

Kural eylemi 'Bağlantıya izin ver' olarak seçilmiştir. Bu izin yalnızca tanımlanan profil ve IP koşullarıyla birlikte geçerlidir.

Yeni Gelen Kuralı Sihirbazı

Eylem

Bağlantı kuralda belirtilen koşullarla eşleştiginde yapılacak eylemi belirtin.

Adımlar:

Kural Türü

Protokoll ve Bağl. Nokt.

Eylem

Profil

Ad

Bir bağlantı belirtilen koşulları sağladığında gerçekleştirilmesi gereken eylem nedir?

☒ **Bağlantıya izin ver**

Buna IPsec ile korunanların yanısıra korunmayan bağlantılar da dahildir.

☐ **Bağlantı güvenliyse izin ver**

Buna yalnızca IPsec kullanarak kimliği doğrulanmış bağlantılar dahildir. Bağlantıların güvenliği IPsec özelliklerindeki ayarlar ve Bağlantı Güvenliği Kuralı düğümündeki kurallar kullanılarak sağlanır.

☐ **Bağlantıyı engelle**

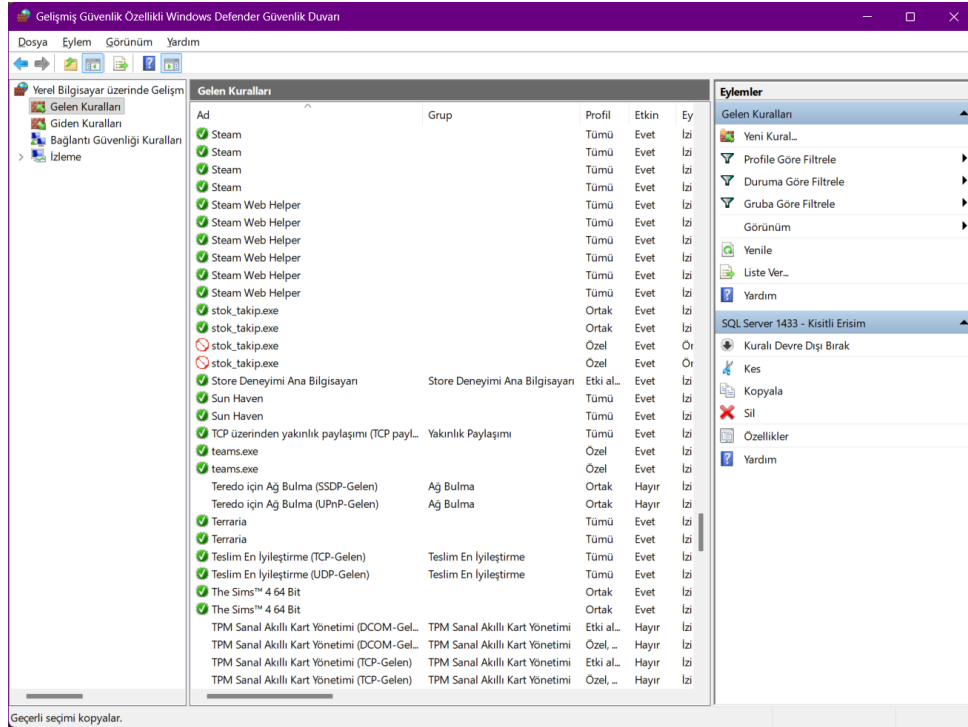
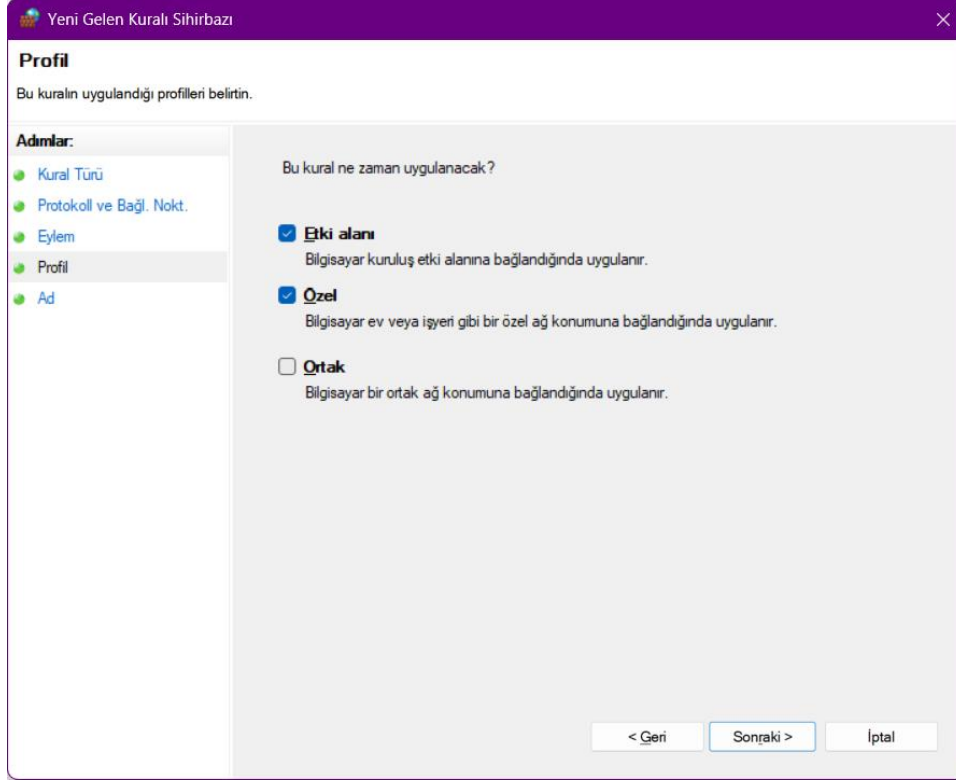
Ozelleştir...

< Geri

Sonraki >

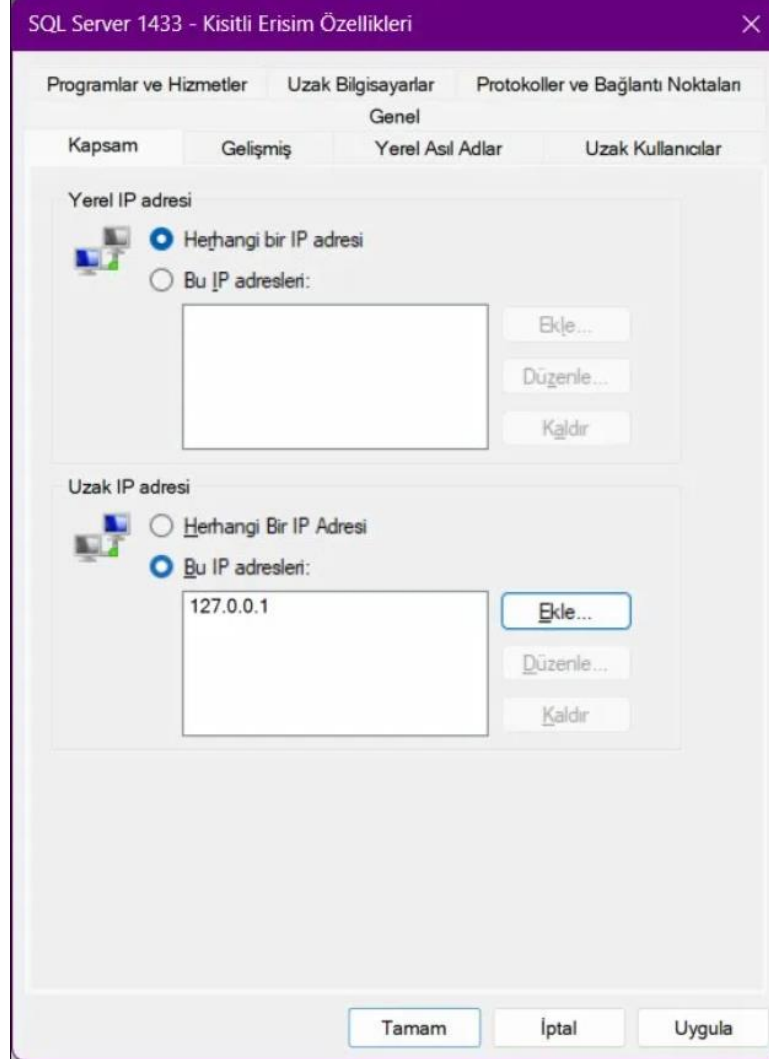
İptal

Güvenlik kuralı yalnızca Domain ve Private ağ profilleri için aktif edilmiştir. Public (ortak) ağ profili devre dışı bırakılarak, kafe, havaalanı gibi güvensiz ortamlardan SQL Server'a erişim engellenmiştir.

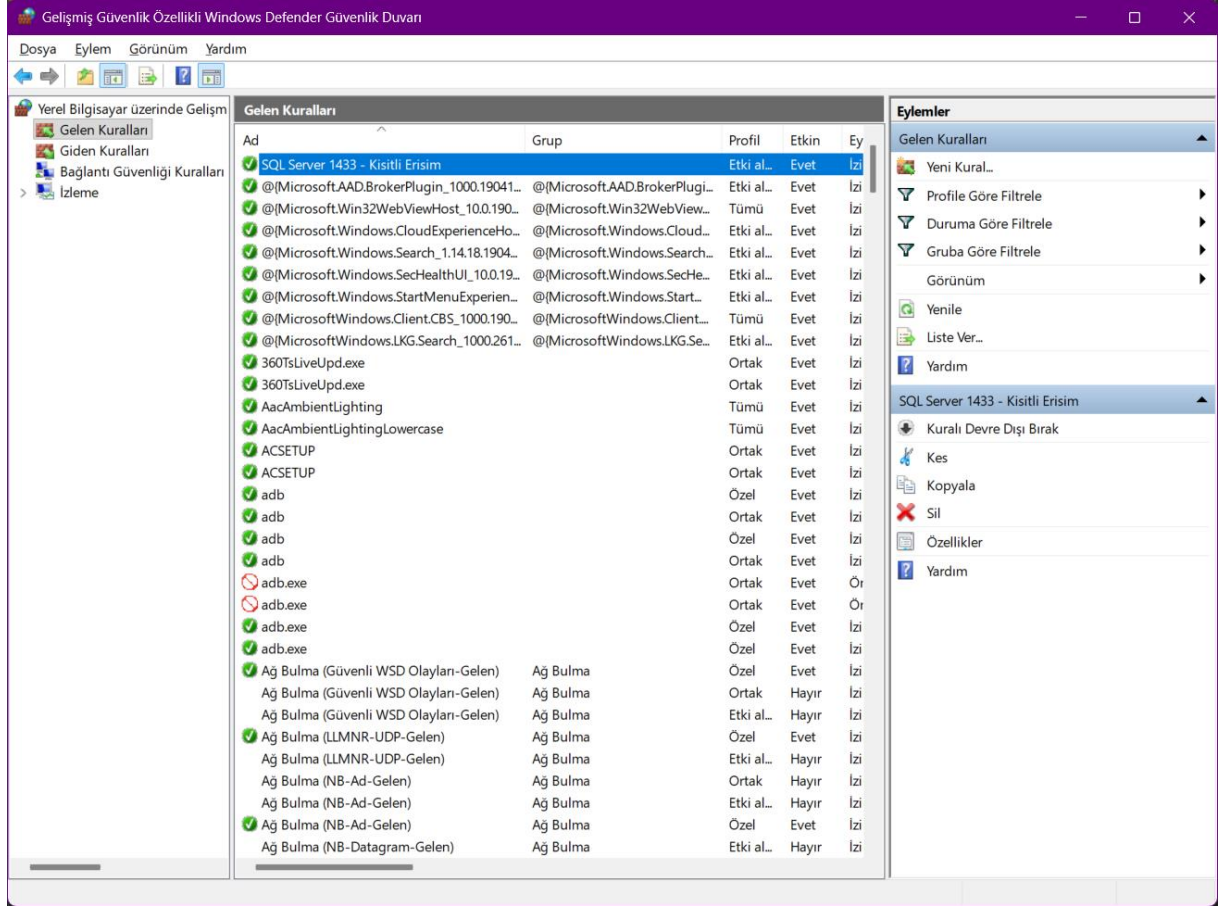


Oluşturulan 'SQL Server 1433 - Kısıtlı Erişim' kuralı Windows Defender Güvenlik Duvarı üzerinde aktif olarak görüntülenmiştir.

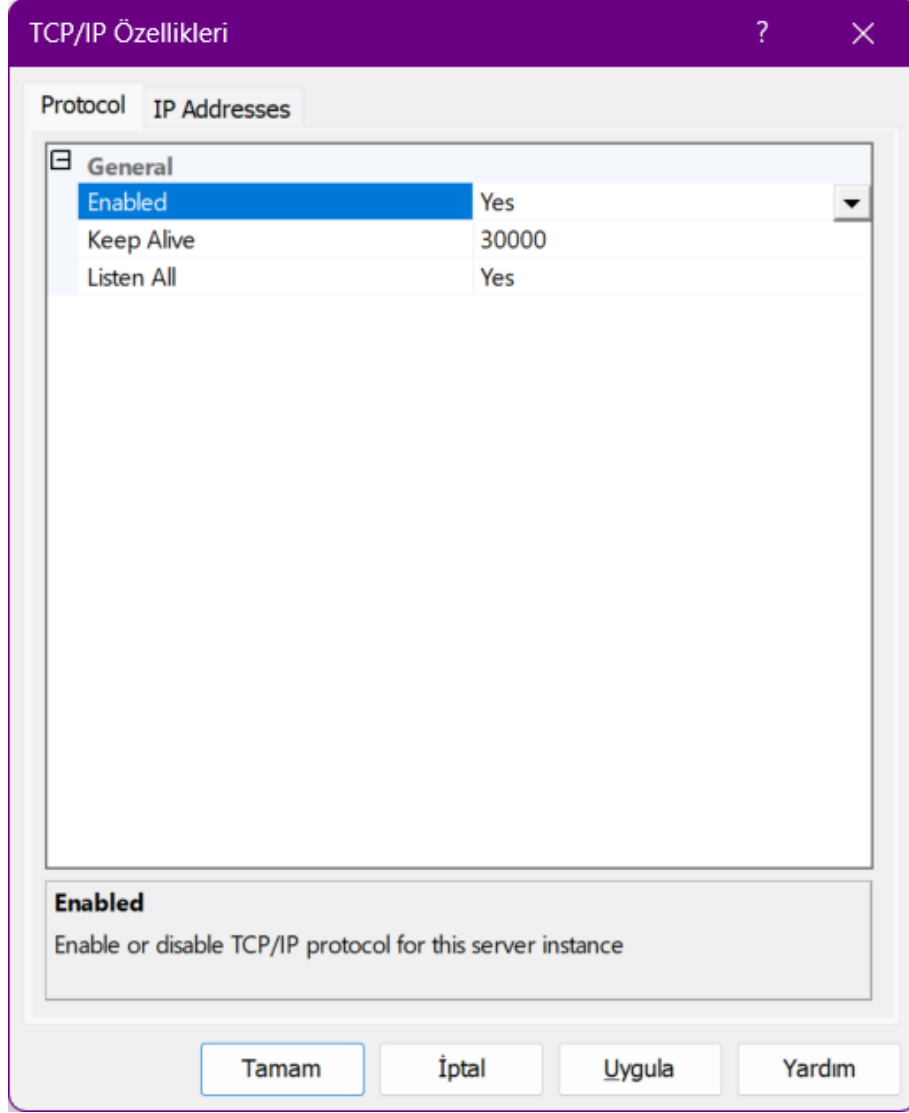
Güvenlik duvarı kuralı kapsamında uzak IP adresi kısıtlaması uygulanmıştır. Yalnızca 127.0.0.1 (localhost) adresinden gelen bağlantılara izin verilmiş, dış ağlardan gelen tüm bağlantılar engellenmiştir. Bu sayede SQL Server yalnızca yerel erişime açık hale getirilmiştir.



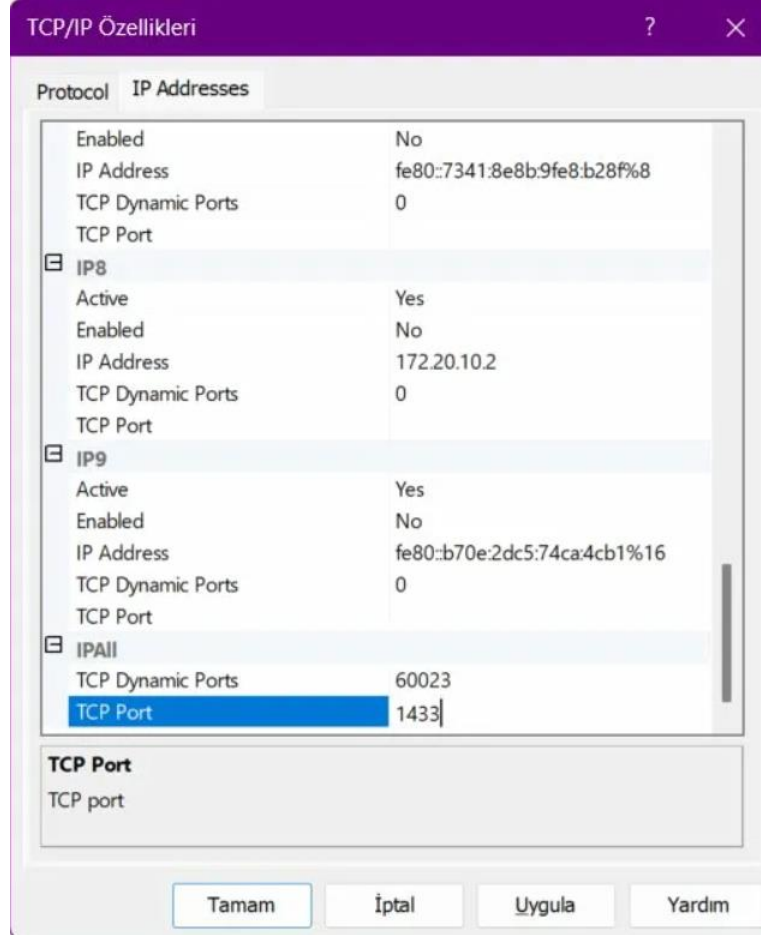
Oluşturulan “SQL Server 1433 - Kısıtlı Erişim” kuralı Windows Defender Güvenlik Duvarı üzerinde aktif olarak görüntülenmiştir. Bu durum yapılandırmanın başarıyla uygulandığını göstermektedir.



SQL Server'ın TCP/IP protokolü aktif hale getirilmiştir. Bu sayede veritabanı sunucusunun TCP üzerinden bağlantı kabul edebilmesi sağlanmıştır.



SQL Server yapılandırması incelenmiş ve TCP portunun 1433 olarak ayarlandığı doğrulanmıştır. Ayrıca dinamik port kullanımı devre dışı bırakılarak sabit port üzerinden bağlantı sağlanmıştır.



6.3 Yapılandırmanın Doğrulanması

SQL Server varsayılan olarak 1433 numaralı TCP portu üzerinden çalışmaktadır. Bu nedenle güvenlik duvarı kuralları bu port üzerinden yapılandırılmıştır.

Yapılandırmanın doğru çalıştığını doğrulamak amacıyla bağlantı kurulurken sunucu adresinde 1433 portu açıkça belirtilmiştir. Bu sayede istemci ile sunucu arasındaki iletişimin tanımlanan port üzerinden gerçekleştiği doğrulanmış ve firewall kuralının etkili olduğu gösterilmiştir.

Sunucuya Bağlan

SQL Server

Oturum açın | **Bağlantı özellikleri** | Always Encrypted | Ek Bağlantı Parametreleri

Sunucu

Sunucu tipi: Veritabanı Altyapısı

Sunucu adı: DESKTOP-DLHAT6J\SQLSERVER

Kimlik doğrulama: Windows Kimlik Doğrulaması

Kullanıcı adı: DESKTOP-DLHAT6J\Asus

Parola:

☐ Şifreyi hatırlama

Bağlantı Güvenliği

Şifreleme: İsteğe bağlı

☒ Sunucu sertifikasına güven

Sertifikadaki ana bilgisayar adı:

Bağlan **İptal** **Yardım** **Seçenekler <<**

SQL Server bağlantısının hangi port ve protokol üzerinden gerçekleştiğini doğrulamak amacıyla aşağıdaki sorgu çalıştırılmıştır:

```
SELECT DISTINCT
    local_tcp_port,
    net_transport
FROM sys.dm_exec_connections
WHERE session_id = @@SPID;
```

Sorgu sonucu bağlantının TCP protokolü üzerinden 1433 portundan gerçekleştiğini doğrulamaktadır. Bu, oluşturulan güvenlik duvarı kuralının doğru port üzerinde etkili olduğunu kanıtlamaktadır.

| | local_tcp_port | net_transport |
|---|----------------|---------------|
| 1 | 1433 | TCP |

7. Sonu

Bu projede Microsoft SQL Server 2022 zerinde kapsamlı bir veritabanı gvenlik altyapısı tasarlanmış ve uygulamalı olarak test edilmiştir.

Eriřim ynetimi kapsamında rol tabanlı yetkilendirme yapılandırılmış, farklı kullanıcıların yalnızca kendilerine tanımlanan işlemleri gerekleřtirebildiđi dođrulanmıştır. TDE ile veritabanı dosyaları disk zerinde řifrelenmiş, fiziksel erişim durumunda veri gvenliđi sađlanmışır. SQL Injection testlerinde dinamik sorguların ciddi gvenlik aıkları oluřturduđu gzlemlenmiş, parametrelili sorgularla bu aık giderilmiştir. Audit logları ile kullanıcı aktiviteleri başarılı ve başarısız işlemler dahil eksiksiz kayıt altına alınmıştır. Gvenlik duvarı yapılandırmasıyla SQL Server yalnızca yerel ađdan erişilebilir hale getirilmiş, dıř bađlantılar engellenmiştir.

Proje boyunca her gvenlik katmanının birbirini tamamladıđı grlmřtr. Yalnızca tek bir nlem almak yerine erişim kontrol, řifreleme, uygulama gvenliđi, izleme ve ađ gvenliđinin bir arada uygulanması sađlam bir gvenlik altyapısı oluřurmaktadır.